UNIVERSITY OF LONDON

MSc ALTERNATIVE ASSESSMENT 2020

For Internal Students of
Royal Holloway

IY5612: Cyber Security

IY5612R: Cyber Security (PAPER FOR RESIT CANDIDATES)

Time Allowed: **THREE hours from download of paper**

Attempt **three** questions

No credit will be given for attempting any further questions

- Answers must be hand-written with module and candidate numbers at the top of each page. Photograph or scan all pages, and retain paper originals for reference by examiners.
- For each attempted question, clearly state the question number.
- Do not include Student ID Number or name, only candidate number
- **Academic Misconduct:** All assessments will be checked for academic misconduct. Any suspected offences will be dealt with under the College's Academic Misconduct procedures.
  - The work submitted is expected to be your own work and only your work. You may not ask for help with the assessments from any source, or copy anyone else's work.
  - You must not give help to anyone else, including sending them any parts of the questions or copies of your solutions, even after the 23-hour time period has finished.

© Royal Holloway University of London 2020

Question 1 Control Systems Security

(a) Cyber-physical systems rely on the use of control systems protocols.

(i) The Modbus TCP protocol is an adaptation of a protocol originally intended for point-to-point connections using the TCP/IP network stack.

i. Describe how a *Master* in a Modbus TCP configuration will send commands and receive status updates (verbally or using a diagram). [4]

ii. How can an adversary with access to a network on which Modbus TCP is being transmitted perform an attack injecting an arbitrary command to a programmable logic controller (PLC)?
Give a detailed description of the steps the attacker must undertake, identifying any defensive or safety mechanisms which must be overcome. [6]

(ii) The OPC UA (Open Platform Communications Unified Architecture) protocol is used widely in industrial control systems (ICS).

i. Identify the characteristics such as performance requirements for an ICS for which OPC UA would be appropriate. [3]

ii. OPC UA provides identification and authentication by way of the public key mechanism forming part of the underlying web service standards (XML, WSDL, SOAP).
Identify how the use of these standards may lead to security *risks* and give an example. [7]

(b) State estimation

(i) Give a brief description or definition of a *state estimation* system and identify one of its application areas. [2]

(ii) Which effect can an adversary achieve by the injection of *bad data* into the state estimation process? Identify one such effect, possibly using the application domain identified in question 1(b)(i) as a reference. [3]

Question 2 Critical Infrastructure Interdependencies

(a) For understanding dependencies in networks, we can rely on different types of graph models.

(i) Given a model of a network in the form of an undirected graph, how can an attacker identify how many nodes of the graph need to be compromised in order to isolate a given part of (fragment) the network?

Give a reasoned answer. [5]

(ii) Consider a network for which we know only that it has a large *diameter*, but where the average *eccentricity* of the vertices is small.

i. Which hypothesis can we form about average path lengths in such a graph? [2]

ii. Can we expect the average and median to be different in this graph? Give a reasoned answer. [3]

(b) Flow models can be employed where it would be insufficient to rely on connectivity only such as when studying network capacity problems.

(i) Which graph model would be appropriate to study a flow problem in a network? [2]

(ii) Identify how an adversary can identify (algorithmically) which node or nodes should be attacked in order to reduce the resource flows between two given nodes. Give a reasoned answer. [5]

(iii) Assume an attacker has successfully attacked a network (e.g. a computer network) based on the analysis conducted in question 2(b)(ii).

What will be the effect on the *rest* of the network? Identify how the attacker can utilise knowledge of these effects in targeting further nodes to attack. Give a detailed answer. [8]

Question 3 Network Robustness

(a) Attacks against power networks:

(i) Identify key constituent elements of an electric power system from generation to residential customer, and where control systems are required to maintain the power network functional and stable. [3]

(ii) For the control systems identified in question 3(a)(i), identify the time-scales at which these must operate, and systems for which it may not be possible to operate a manual fall-back control. [4]

(b) The routing infrastructure of the Internet relies on the BGP (Border Gateway Protocol) and can be subject to attacks.

(i) It is possible to contaminate routing tables and to redirect traffic by way of a *Prefix Hijacking Attack*.

Describe how and under which conditions an attacker with access to a BGP-speaking Autonomous System (AS) can perform such an attack, and what countermeasures can be taken to detect such an attack. Give a reasoned answer. [8]

(ii) The IETF has adopted the Resource Public Key Infrastructure (RPKI) model to address problems such as the attack identified in question 3(b)(i).

Identify how the use of RPKI will allow to defend against (i.e. not just mitigate) prefix hijacking, and what would be required to make this defence *effective*? [6]

(iii) The robustness of a connection between BGP AS depends on the availability of alternative routes. Explain the concept of *route diversity* and why BGP will not always be able to establish an alternative route between two AS even if these are logically connected. [4]

Question 4 Cyber Security Analysis

(a) Advanced Persistent Threats:

(i) Briefly define APTs (Advanced Persistent Threats) and give at least one key characteristic of APTs that distinguish these from generic malware distribution and propagation mechanisms. Give a reasoned answer. [4]

(ii) Identify and briefly describe each of the stages in a *cyber kill chain* used to analyse advanced persistent threats in particular. [7]

(b) Attack Structures:

(i) Describe the concept of a *supply chain attack* in the context of an (APT) cyber attack, and give an example of such an attack. [7]

(ii) If a nation state were to be the victim of a cyber attack in which critical infrastructure such as power networks are severely disrupted, leading to loss of life: What problems can arise in identifying the *origin* of such an attack? [4]

(iii) Can a nation state avoid being cast as the origin of an attack as identified in question 4(b)(ii)? Give a reasoned answer. [3]

Question 5 Attack and Adversary Modelling

(a) A common approach in cyber risk mitigation is the use of best practices and to analyse vulnerability against common threats (e.g. SANS Top 20 lists).

Give a reasoned explanation why this approach will not be effective for countering reasonably sophisticated adversaries. [5]

(b) Attack trees:

(i) Basic Attack Trees offer a mechanism for studying how an attacker can achieve a particular objective.

How will this approach help in allocating resources for defensive measures? Give a reasoned answer or example. [5]

(ii) Attack-Defence trees allow the study of interactions between attackers and defenders.

Construct an attack-defence tree for an adversary wanting to steal a file containing trade secrets from an executive's laptop. [10]

(c) Identify which aspects of adversarial interaction a game-theoretical model can capture that are not equally possible to identify in an attack-defence tree. Give a reasoned answer. [5]

END

Stephen Wolthusen

Model Answers

Question 1 Control Systems Security

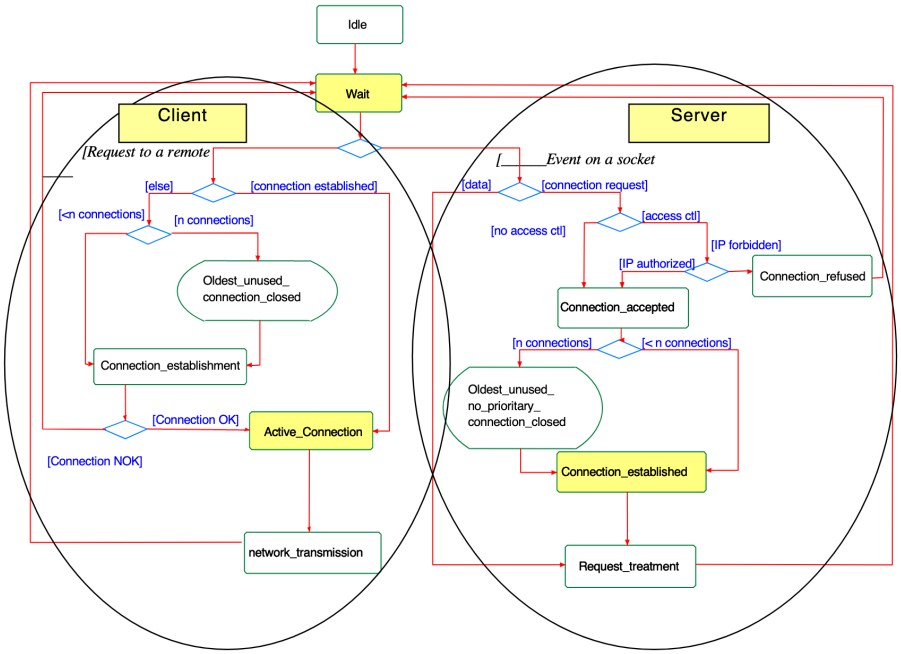
Cogent answers are awarded full marks.

(a) CPS protocols:

(i) Modbus TCP:

i. Modbus TCP operates in a master–slave configuration where communication is always initiated by the master. (1)
For a status update, it will send a request ADU to a slave unit with appropriate function code and information on what to read (2).
This is then replied to by the slave with the same function code and data or an error code, respectively. (1)

ii. An attacker must be able to inject messages onto the network segment containing the target (slave), this may be impeded by firewall rules. (1)
Modbus TCP will typically retain TCP connections open for a period of time to avoid having to repeat TCP handshakes; therefore a command injection may require a TCP session hijacking attack or the forcing of a session termination to avoid messages being ignored or causing error conditions. (4)
A final requirement is the ability to construct a message that has a valid *transaction identifier*. (1)



(ii) OPC UA:

i. OPC UA relies on an extensive protocol stack and services by the operating system, neither of which are designed for real-time behaviour. No response times or timing characteristics such as jitter bounds can be guaranteed by OPC UA. (2)
It is therefore only suitable for use in *soft* real-time systems when combined with over-provisioning. (1)

ii. The web service stack used by OPC UA contains an extensive code base which is susceptible to implementation flaws. (2)
The encoding used (based on XML) is, moreover, susceptible to attacks on the parsing mechanism that can affect the performance of the parser and therefore responsiveness, further affecting real-time characteristics. (2)
Finally, a further risk of breaching already loose guarantees for quality of service arises from the use of a distributed architecture for authentication and authorisation in the form of Microsoft Active Directory and public key infrastructure; any delay or disruption in these services will hinder authentication and authorisation of

commands. (3)

(b) State estimation:

(i) State estimation systems are used where the exact state of a system cannot be determined owing to insufficient variables being measured. State estimator algorithms seek to extrapolate state and missing variables, relying on iteratively reducing residual error. (1)

A typical application domain would be for independent system operators in power systems to determine system state (alternative answers might e.g. refer to digital twin systems) (1)

(ii) Bad data injection will result in the state estimate diverging (further) from the true state. A state estimator would discard implausible values, hence injection will have to follow constraints. However, within such constraints an attacker can modify the data in such a way that over time a particular state is being *forced* as the estimate drifts further from the nominal. (3)

Question 2 Critical Infrastructure Interdependencies

(a) Graph models:

(i) For an undirected graph, isolating a part is to remove vertices so that the remaining graph is split into multiple components, one of which is the target fragment. (3)

The number of vertices to be removed is determined by the number of vertex-independent paths connecting the fragment to other components; this in turn is a consequence of Menger's theorem and allows the identification of a *cut set*. (2)

(ii) Graph statistics:

i. For graph with large diameter but small *average* eccentricity, the hypothesis is that the diameter is driven by a small number of vertices with large eccentricity. (2)

ii. Yes, the two values will be quite different since the average is skewed by the few outliers. (3)

(b) Flow models:

(i) For this we need to have a directed, weighted graph. (2)

(ii) The adversary can resort to any number of flow problems; the most effective approach for this question is a *greedy* algorithm (the lecture covered the Ford-Fulkerson algorithm, but others such as Dinic's algorithm would be equally applicable. (3)

These algorithms identify the maximum residual flow in a given step; these would be best to target individually. (2)

(iii) An attacker able to observe the network can then pursue a strategy of maximising harm.

For this the flows between remaining nodes in the network need to be studied and similarly disrupted (algorithmic sketch would be preferable). (3)

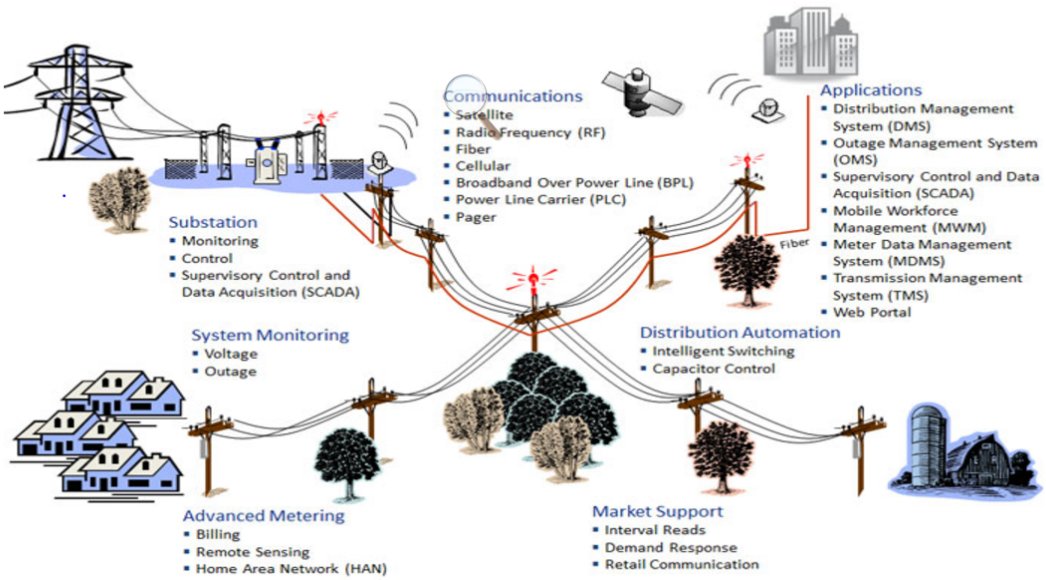
Flow pairs may share vertices and hence an attack on one vertex may be able to impede more than one possible flow, although not

necessarily at the same time since this is limited by the respective capacity. (5)

Question 3 Network Robustness

(a) Power network attacks:

(i) Identifying control systems for generation, transformation and substations are sufficient for attaining full marks. (3)



(ii) Monitoring and control systems for safety parameters need to respond in the millisecond range to prevent harm to life and equipment; other elements such as demand response can operate on time scales of minutes and are more amenable to manual fall-back, which are not possible for the former. (4)

(the above are merely examples, similar considerations will be given full marks)

(b) BGP:

(i) Any BGP speaking system (AS) is initially free to announce that it has access to an efficient route to a particular prefix, or is in fact the owner of this prefix. (2)

The attacker will only need to announce specific route for the prefix, which then is considered preferable over a more general (equivalent) under the BGP protocol. (2)

Other BGP systems can monitor for the announcement of such rogue prefixes and filter out ones which are known to be problematic. (2)

A mitigation mechanism then needs to consist of announcing yet-more specific legitimate prefixes. (2)

(ii) RPKI allows the originators of a prefix to explicitly authorise route announcements (ROAs). This lets a router verify whether the announcement is authorised to originate a prefix through digital signatures. (2)

In addition to ROAs, however, mitigating the attack in question 3(b)(i) also requires *routes* to be validated; for this RPKI is used by BGPsec. (2)

To be effective, the entire *path* must be covered by a sequence of BGPsec signatures, any intermediate system not honouring BGPsec would invalidate the chain of signatures along the path. (4)

(iii) Route diversity is achieved if (at the level of AS modelling) vertex independence is achieved. (2)

BGP may not be able to route traffic between two AS even if multiple vertex-independent paths exist at the level of graph connectivity since BGP is a policy-based protocol and policy decisions can affect which routes are announced or permitted transit. (2)

Question 4 Cyber Security Policy and Strategy

(a) APTs:

(i) APTs are generally considered to be operating in the interest of nation states, and can be distinguished by a number of characteristics (only some characteristics are required for full marks, alternative definitions are also acceptable) (4):

- Adversary objectives
- Timelines, longer and repeated probing
- Resources, knowledge and tools used in the event
- Risk tolerance (by the adversary)
- Skills and methods
- Actions
- Attack origination points, particularly use of lateral movement in target system
- Numbers (resources) involved in the attack: How many internal and external systems were involved in the event
- Knowledge sources

(ii) The cyber kill chain consists of seven stages:

i. Reconnaissance: Intruder selects target, researches it, and attempts to identify vulnerabilities in the target network. (1)

ii. Weaponization: Intruder creates remote access malware weapon, such as a virus or worm, tailored to one or more vulnerabilities. (1)

iii. Delivery: Intruder transmits weapon to target. (1)

iv. Exploitation: Malware weapon's program code triggers, which takes action on target network to exploit vulnerability. (1)

v. Installation: Preparing access point usable by intruder. (1)

vi. Command and Control: Malware enables intruder to have remote, persistent access to target network. (1)

vii. Actions on Objective: Intruder takes action to achieve their goals, such as data exfiltration, data destruction, or encryption for

ransom. (1)

(b) Attack structures:

(i) A supply chain attack targets a resource used by the actual objective; this can be software used, the systems of a contractor or supplier, or even hardware components. The assumption is that security controls over such resources will be more limited in scope than for internal resources. (3)

An example of such an attack is the compromise of a software package (or update) known to be used by the target. By embedding stealthy malware in this package, it an attack will not be immediately visible compared to a network-based attack, and configuration changes will be more likely to be ascribed to the desired software package. (4)

(ii) The problem with determining the origin lies in (timely) attribution. (1) When critical infrastructures are affected, the priority will need to be on returning to operational status rather than gathering of forensic evidence (2). The attacker may also destroy evidence as part of the attack and use obfuscatory techniques for hiding any malicious code and communications. (1)

(iii) It would be relatively difficult to credibly deny culpability since attribution will generally need to rely on circumstantial information which is susceptible to being generated fraudulently in a *false flag operation*.

Specifically, some information on how the target's APTs have operated will allow the creation of a targeted attack that is sufficiently consistent with sources, methods, and objectives of the target. (3)

Question 5 Advanced Attacks

(a) A sophisticated attacker will conduct reconnaissance and hence not target any systems or objectives that have been hardened as a result of mitigating a fixed check list.

For a given objective, the attacker would be free to investigate alternative means of securing the same objective, potentially in an indirect way, thereby negating the effort spent on the mitigation. (5)

(b) Attack trees:

(i) An attack tree will allow the identification of all possible ways of securing the same objective.

Defensive measures can then be allocated based on *cut sets* of required steps by the attacker, i.e. where more than one step is required for an attack to succeed, blocking any one will suffice. (3)

In addition to enumerating the number of ways of achieving the objective, this also helps to identify elements shared by multiple objectives and their cut sets, which can then be prioritised for mitigation. (2)

(ii) Candidates should construct a credible attack-defence tree with multiple sub-objectives and defensive measures.

To obtain full marks the AD tree semantics need to be sufficiently exercised, clearly identifying how attackers and defenders interact. (10)

(c) Several answers are possible, the following should be considered an example.

Game-theoretical models allow the modelling of interactions between attackers and defenders in multiple rounds. This is particularly relevant where mixed strategies are considered. (3)

AD trees also do not allow the modelling of the attacker possessing incomplete information whereas there exist game-theoretical models in which the choice of strategy of players (both attackers and defenders)

not possessing full information on the state of the game need not be taken based on this assumption. (2)